Document post-fuite — Fixture

Document post-fuite

Fixture

Ce qui est sorti, et combien de temps cela continue de nuire · 01/11/2026 22:54 UTC

1. Objet, et ce que ce document n'est pas

Domaines déclarés touchés : 2. La confidentialité promise n'est pas tenue sur 1, pour 1 année, et un engagement reste dû jusqu'en 2036.

Ce document répond à une seule question, celle que l'inventaire et le rapport d'audit ne savent pas poser : l'incident est terminé, combien de temps continue-t-il de coûter ? Il se lit à côté du rapport technique, jamais à sa place.

Ce n'est pas une notification de violation. L'article 33 du RGPD demande les catégories et le nombre approximatif de personnes et d'enregistrements concernés : ce document n'en contient aucun et n'en déduit aucun. Ce décompte appartient à l'équipe incident et au délégué à la protection des données ; celui des années est ici.

2. Ce qui a été déclaré sorti

Ces durées et ces dates sont une donnée d'entrée fournie par votre organisation. L'outil ne peut ni les vérifier ni les déduire du code, et tout ce qui suit en dépend : une durée corrigée change les chiffres de la section 3.

Domaine	Sortie	Durée (ans)	Déclarée par	Justification fournie
backups	29/07/2026	10	auteur et date inconnus	Holds the whole database, including ten years of accounting records.
session tokens	29/07/2026	1	auteur et date inconnus	

3. Combien de temps chaque domaine reste protégé

Des données sorties en année F doivent rester secrètes jusqu'en F + durée. L'algorithme qui les protège cesse d'être crédible en 2035. Ce qui se trouve entre les deux est la part qui devient lisible, et migrer après ne la rattrape pas.

Domaine	Dû jusqu'en	Protégé jusqu'en	Années lisibles	À partir de	Protection relevée
backups	2036	2035	1	2036	AES-256, RSA
session tokens	2027	au-delà de la durée demandée	—	—	AES-256

Les lignes surlignées sont celles dont l'engagement de confidentialité dépasse la protection. Une ligne sans chiffre tient la durée demandée, par un algorithme que le quantique n'atteint pas ou parce que l'engagement se termine avant la péremption.

4. Ce qui peut encore être fait, et ce que cela rattrape

Une seule des mesures ci-dessous touche aux données déjà sorties. Les trois autres protègent la copie suivante, ce qui est nécessaire et n'est pas la même chose.

- Renouveler les clés, secrets et accès qui étaient dans le périmètre. — ne change rien à ce qui est sorti.

- Réduire la durée de conservation là où elle est un choix et non un plancher légal : c'est le seul levier qui diminue les chiffres de la section 3, parce qu'il réduit la durée pendant laquelle ces données doivent encore rester secrètes. — atteint ce qui est sorti.
- Rechiffrer ce qui est encore détenu avec un algorithme dont la péremption est postérieure à la durée demandée. — ne change rien à ce qui est sorti.
- Notifier qui doit l'être, dans les délais que votre régime impose. Ce document ne le fait pas. — ne change rien à ce qui est sorti.

5. Méthode et limites

Le raisonnement est celui de l'inégalité de Mosca (2015), lu à l'envers : l'adversaire n'attend plus, il détient la donnée, et la seule question est la part de la confidentialité demandée que la cryptographie peut encore tenir.

année de sortie + durée de confidentialité déclarée > péremption de l'algorithme => la différence est la part qui devient lisible

- Les domaines traités sont ceux que quelqu'un a déclarés touchés. Une table volée n'est pas une affirmation sur tout le système, et l'outil n'en déclare aucun de lui-même.
- L'outil ne sait pas ce qui est réellement sorti, ni si c'est sorti chiffré. Il raisonne sur ce que les fichiers montrent comme protection et sur ce que vous avez déclaré comme durée.
- Il ne sait pas si les clés sont parties avec les données. Si elles sont parties, la colonne « protégé jusqu'en » ne vaut rien et toute la durée est perdue, comme pour une donnée en clair.
- Il ne compte ni enregistrements ni personnes, et ne doit pas être cité comme s'il en comptait.

Commande exécutée : ./bin/sablier scan tests/fixtures/sample --breached=2026-07-29 --incident=examples/incident.html --out=examples/.tmp/report.html --pdf=examples/.tmp/report.pdf --no-probe --quiet

6. Intégrité du document

Empreinte des constatations sur lesquelles ce document est construit. La même commande sur le même état du dépôt produit la même empreinte.

92cd7996cbe685ae50aae64e425865da36bd3c25b0ac6341ca1668dfd1e5431d

Ce rapport n'est pas signé. Pour qu'un tiers puisse établir qu'il n'a pas été modifié depuis son émission, relancer l'analyse avec l'option de signature.